# Friendly Remediation Report for Tlalpan

*Plain-language report for readers who do not work in technical or security roles.*

## Quick summary

Tlalpan shows a critical level of risk with score 83/100 based on 12 main issue(s). This version explains the situation in simpler language, keeps the uncertainty visible, and highlights the most important next actions first.

## Basic context

- Target: Tlalpan
- Public ID: mx-cdmx-tlalpan
- Audience: Friendly / nontechnical
- Generated at: 2026-01-01T00:00:00.000Z
- Generated by: deterministic-fallback

## Most important next actions

1. Priority 1: Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release. Why it matters: wordpress 6.4; confidence 0.8; references CVE-2024-31210.
2. Priority 2: Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release. Why it matters: wordpress 6.4; confidence 0.8; references CVE-2024-31210.
3. Priority 3: Enable forced secure browsing rule after confirming HTTPS is stable for the site and subdomains. Why it matters: strict-transport-security was not present in the selected response headers.
4. Priority 4: Add a tested Content-Security-Policy that limits script, frame, and object sources. Why it matters: content-security-policy was not present in the selected response headers.
5. Priority 5: Send browser setting that blocks unsafe file-type guessing: nosniff on HTML and static asset responses. Why it matters: browser setting that blocks unsafe file-type guessing was not present in the selected response headers.

## What this report covers

Tlalpan was treated as the scoped public-facing target for this report. The report generator normalized the available structured input and limited the output to the provided target context.

- Primary public URL: https://www.tlalpan.cdmx.gob.mx

- Region or state reference: Ciudad de Mexico

## What was allowed

No explicit authorization object was supplied. The report generator treated the input as evidence-only and did not add new tests or claims.

- No detailed authorization fields were supplied in the current input payload.

## How the review was done

The report was assembled from structured inputs, normalized into a consistent evidence model, and then rendered into audience-specific fix guidance.

- Reviewed structured scan evidence for https://www.tlalpan.cdmx.gob.mx.
- Normalized flexible structured input into a consistent report contract before generating the PDFs.
- Preserved only evidence-backed observations and did not add new findings without source support.
- Excluded exploit payloads, credential use, and operational attack instructions from the output.

## What needs attention

These are the main issues that deserve attention first. The list is ordered by likely impact and by how clear the available evidence is.

- high: 2
- medium: 8
- low: 2
- Top issue: WordPress 6.4 requires patch review
- Top issue: WordPress 6.4 requires patch review
- Top issue: Missing browser rule that forces secure connections

## Issue-by-issue explanation

### 1. WordPress 6.4 requires patch review

- Severity: high
- Status: observed
- Confidence: high
- Category: known-vulnerability

**Description**

The scanner observed a WordPress 6.4 generator string. This MVP treats the version as a known-risk demo match when confidence is high, without claiming exploitation.

### Evidence

wordpress 6.4; confidence 0.8; references CVE-2024-31210.

### Recommended remediation

Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release.

### Remediation steps

- Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release.
- Assign an owner and due date before treating the item as resolved.

### Verification steps

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for wordpress 6.4 requires patch review and compare it with the current evidence.

## 2. WordPress 6.4 requires patch review

- Severity: high
- Status: observed
- Confidence: high
- Category: known-vulnerability

### Description

The scanner observed a WordPress 6.4 generator string. This MVP treats the version as a known-risk demo match when confidence is high, without claiming exploitation.

### Evidence

wordpress 6.4; confidence 0.8; references CVE-2024-31210.

### Recommended remediation

Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release.

### Remediation steps

- Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release.
- Assign an owner and due date before treating the item as resolved.

### Verification steps

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for wordpress 6.4 requires patch review and compare it with the current evidence.

## 3. Missing browser rule that forces secure connections

- Severity: medium
- Status: observed

- Confidence: medium
- Category: headers

**Description**

A baseline browser security response header was not observed in the safe public HTTP response.

**Evidence**

strict-transport-security was not present in the selected response headers.

**Recommended remediation**

Enable forced secure browsing rule after confirming HTTPS is stable for the site and subdomains.

**Remediation steps**

- Enable forced secure browsing rule after confirming HTTPS is stable for the site and subdomains.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing browser rule that forces secure connections and compare it with the current evidence.

## 4. Missing browser rule that limits what the site can load

- Severity: medium
- Status: observed
- Confidence: medium
- Category: headers

**Description**

A baseline browser security response header was not observed in the safe public HTTP response.

**Evidence**

content-security-policy was not present in the selected response headers.

**Recommended remediation**

Add a tested Content-Security-Policy that limits script, frame, and object sources.

**Remediation steps**

- Add a tested Content-Security-Policy that limits script, frame, and object sources.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing browser rule that limits what the site can load and compare it with the current evidence.

## 5. Missing browser setting that blocks unsafe file-type guessing

- Severity: medium
- Status: observed
- Confidence: medium
- Category: headers

**Description**

A baseline browser security response header was not observed in the safe public HTTP response.

**Evidence**

browser setting that blocks unsafe file-type guessing was not present in the selected response headers.

**Recommended remediation**

Send browser setting that blocks unsafe file-type guessing: nosniff on HTML and static asset responses.

**Remediation steps**

- Send browser setting that blocks unsafe file-type guessing: nosniff on HTML and static asset responses.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing browser setting that blocks unsafe file-type guessing and compare it with the current evidence.

## 6. Public admin path is reachable

- Severity: medium
- Status: observed
- Confidence: medium
- Category: admin-exposure

**Description**

One or more common website management software or generic admin paths responded successfully to safe safe public checks.

**Evidence**

/wp-login.php returned 200.

**Recommended remediation**

Restrict administrative entry points with access controls, MFA, and monitoring where operationally possible.

**Remediation steps**

- Restrict administrative entry points with access controls, MFA, and monitoring where operationally possible.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for public admin path is reachable and compare it with the current evidence.

## 7. Missing browser rule that forces secure connections

- Severity: medium
- Status: observed
- Confidence: medium
- Category: headers

**Description**

A baseline browser security response header was not observed in the safe public HTTP response.

**Evidence**

strict-transport-security was not present in the selected response headers.

**Recommended remediation**

Enable forced secure browsing rule after confirming HTTPS is stable for the site and subdomains.

**Remediation steps**

- Enable forced secure browsing rule after confirming HTTPS is stable for the site and subdomains.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing browser rule that forces secure connections and compare it with the current evidence.

## 8. Missing browser rule that limits what the site can load

- Severity: medium
- Status: observed
- Confidence: medium
- Category: headers

**Description**

A baseline browser security response header was not observed in the safe public HTTP response.

**Evidence**

content-security-policy was not present in the selected response headers.

**Recommended remediation**

Add a tested Content-Security-Policy that limits script, frame, and object sources.

**Remediation steps**

- Add a tested Content-Security-Policy that limits script, frame, and object sources.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing browser rule that limits what the site can load and compare it with the current evidence.

## 9. Missing browser setting that blocks unsafe file-type guessing

- Severity: medium
- Status: observed
- Confidence: medium
- Category: headers

**Description**

A baseline browser security response header was not observed in the safe public HTTP response.

**Evidence**

browser setting that blocks unsafe file-type guessing was not present in the selected response headers.

**Recommended remediation**

Send browser setting that blocks unsafe file-type guessing: nosniff on HTML and static asset responses.

**Remediation steps**

- Send browser setting that blocks unsafe file-type guessing: nosniff on HTML and static asset responses.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing browser setting that blocks unsafe file-type guessing and compare it with the current evidence.

## 10. Public admin path is reachable

- Severity: medium
- Status: observed
- Confidence: medium
- Category: admin-exposure

**Description**

One or more common website management software or generic admin paths responded successfully to safe safe public checks.

**Evidence**

/wp-login.php returned 200.

**Recommended remediation**

Restrict administrative entry points with access controls, MFA, and monitoring where operationally possible.

**Remediation steps**

- Restrict administrative entry points with access controls, MFA, and monitoring where operationally possible.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for public admin path is reachable and compare it with the current evidence.

## 11. website management software fingerprint was detected

- Severity: low
- Status: observed
- Confidence: low
- Category: cms

**Description**

Public page evidence revealed a likely website management software fingerprint. This is informational unless combined with other risk evidence.

**Evidence**

wordpress 6.4; confidence 0.8; evidence generator:WordPress 6.4, marker:wordpress.

**Recommended remediation**

Keep website management software core, extensions, and themes patched, and remove unnecessary public version disclosures where practical.

**Remediation steps**

- Keep website management software core, extensions, and themes patched, and remove unnecessary public version disclosures where practical.
- Assign an owner and due date before treating the item as resolved.

**Verification steps**

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for website management software fingerprint was detected and compare it with the current evidence.

## 12. website management software fingerprint was detected

- Severity: low
- Status: observed
- Confidence: low
- Category: cms